



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

DevSecOps – part 1

Michele Colajanni

Dipartimento di Informatica – Scienza e Ingegneria
michele.colajanni@unibo.it

It's time to “re-boot” the software industry

The **software industry is still immature**, but:

- the Web has become a programming environment and no longer just a publishing environment
- the business and the entire society are founded on digital services
- software-assisted collaboration is increasing
- the AI is exploding

Will software industry develop fast enough to fill the *complexity* and *security* at scale requirements foreseeable by 2030?

We need a fundamental change and not just incremental progress to create culture, tools, norms for the next software generation that will power a user-driven world of mass



Justifications

- 1) There are not enough experts (unfortunately, there never will be)
- 2) Speeds and tool adoption are prioritized over security
- 3) Innovation has outpaced security

Truth

There are never been economic incentives for good software

“Your computers are not safe. Not the software, not the hardware, not the networks that connect them together ... And companies that build these things don’t care and have no reason to worry because failure doesn't cost them anything.” [Hackers LOpht Dildog, 1998, to Senate Commission]



Economic incentives and disincentives for software

The digital market has always rewarded

- quick development of products
- continuous production of novel features
- spying on users
- collecting and selling data of customers

Regardless of what they say, the digital market has never rewarded

- security and privacy
- safety
- transparency
- reliability past a bare minimum
- resilience at all

...SO FAR



Secure Development and Operations (*DevSecOps*)

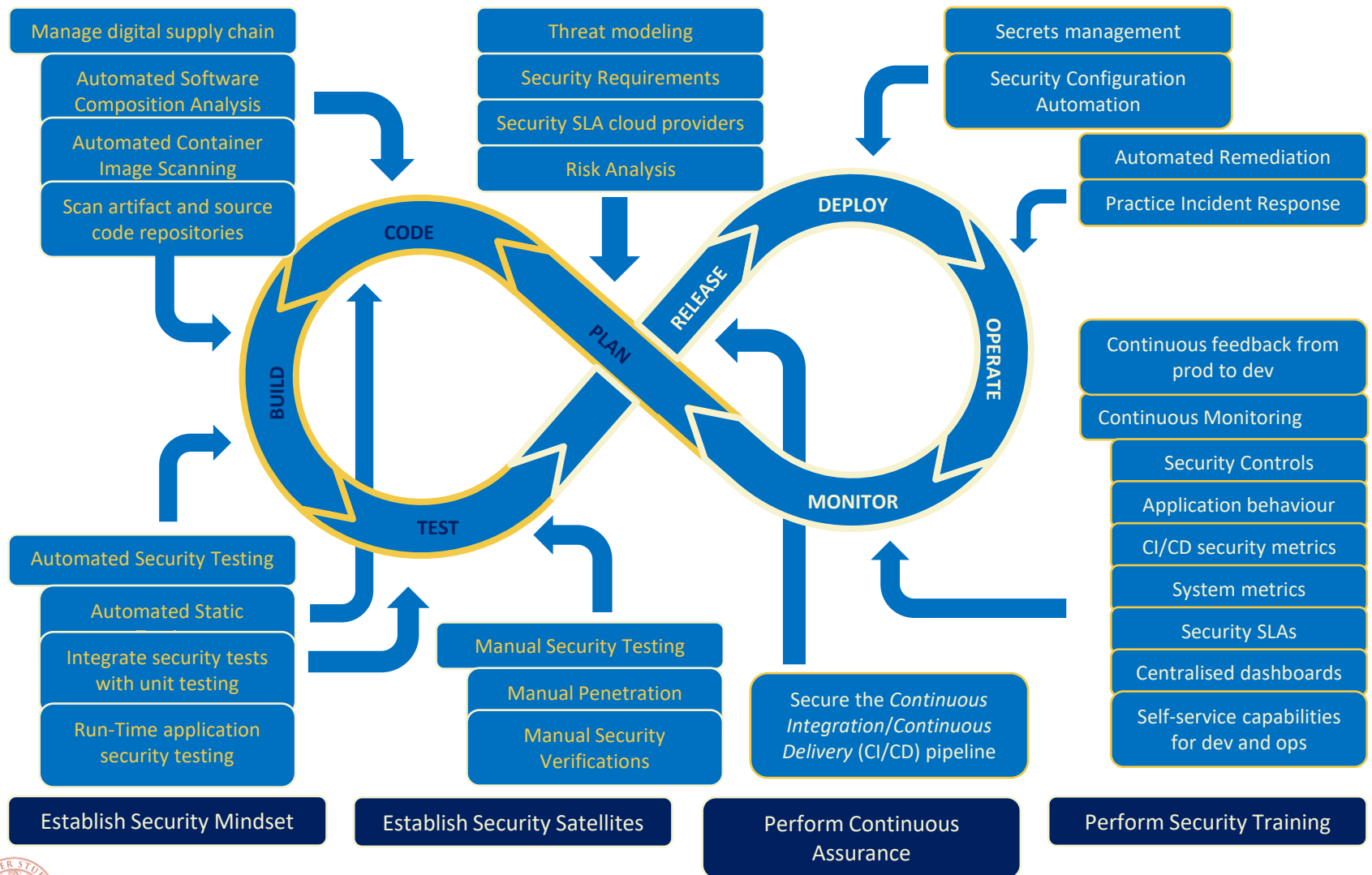
Software quality development, reliability and security are not just steps of the journey. They are the journey

- Approaches based on iterations over small units of work promote better testing, fast feedback and room for experimentation. This is the best approach to build complex and secure software systems and to guarantee their long term maintenance
- Cybersecurity is seen as an obstacle for DevOps adoption. Hence, cybersecurity has been treated as an afterthought, only when and if some vulnerabilities are found

MODERN GOAL: To integrate security assurance in DevOps cycle without increasing (much) delay



The overall picture of *DevSecOps*



Method towards *DevSecOps* (1)

1) Destroy the silos mindset!

Silos is a mentality. It is a long term cage

- Change the mentality
- Create a common goal (“we have to create reliable and secure software”), a common language, a common set of practices
- Share operational and cybersecurity learning experiences and create a security mindset among all designers, developers, testers, IT ops specialists, quality assurance engineers, reliability experts
- Distribute responsibility (scalability, reliability, cybersecurity) to the entire team and create supporting mechanisms and tools to get the job done



Methods towards *DevSecOps* (2)

2) Use all facilities

- Adopt the same platform: invent one, modify one
- Leverage validation and cybersecurity automation capabilities wherever possible
- Tools can help, but they do not solve all problems

3) Use measures and feedbacks

- Establish operational, reliability and cybersecurity measurements to gain insights
- Create learning opportunities from anomalies and errors
- Reduce delay over other aspects (cost, licensing, reporting, ...)



What is *DevSecOps* really?

**DevSecOps is a mindset, a culture and a practice,
not a tool neither a platform!**

- It requires a **novel mentality** and a **cultural shift** within an organization as much as **new technological approaches, competences and toolsets**
- This means bridging gaps between teams that have traditionally worked independently with their own tools and workflows, and often with different KPIs



What is the need of DevSecOps?

- For years, software developers used **waterfall models**, which were sufficient to serve the core purposes
- However, for today's organizations, operations, data security and compliance are major components to address and here, waterfall models and even *DevOps* disappoint
- When software developers are unable to identify cyber vulnerabilities, we open the possibility to malware and attacks
- *DevSecOps* comes into this critical picture
 - It integrates security into software development by creating partnerships between the security team and software developers
 - Developers, cybersecurity and operational people can work together and identify and fix security vulnerabilities before they can take any actions



DevSecOps principles

DevSecOps refers to a unique software engineering culture that is built on cybersecurity and resilient operations

It introduces security at the early stage of the software development lifecycle to achieve service objectives and to mitigate unreliability and security risks

- **DevSecOps is**
 - Security automation
 - Security at scale
 - Discussing security and business trade-offs
- **DevSecOps does not promote an ivory tower cybersecurity**
 - “I’m only here just to audit the code”



Rethinking the organization even for the future

- DevSecOps addresses security risks and vulnerabilities from the beginning, so organizations can quickly mitigate or altogether avoid damaging and costly surprises that might have otherwise appeared in later phases
- Organizations adopting DevSecOps can also implement continuous cybersecurity operations and reliability testing, meaning their services remain protected around the clock, every day of the year



Reorganizations are not so easy

- Not much else disrupts performance more than a strong reorganization
- Blowing up the organizational structure may seem the answer, but big change is so massively disruptive that the majority of people resist it and freak out, consumed by anxiety over future unknowns
- There is an important thing that is necessary to know about humans and silos: **People don't trust people that they don't know well.** “The social instincts of humans adapted only for **small groups**. When the band grew too large, its social order destabilized and the band split. There was no way so many strangers could live together.” [*Sapiens*, Harari]
- In today's digital age, consider how large, complex organizations drive the need for specialization. This leads to **different goals, different metrics, and different incentives** – resulting in conflicting priorities and miscommunication. Just blowing up silos might not be the answer
- **Even though we are not hunting anymore for our survival, we still need to find trust** in those we work with for the survival of business



Rethinking the organization even for the future

- Looking ahead, it is likely that *DevSecOps* will not only occupy a bigger place in the software development process, but **it also become more fundamental to the overall success of companies and their ability to thrive in the data-driven epoch**
 - While building and sustaining a *DevSecOps* culture does not happen overnight
 - Rethinking the development pipeline with a *DevSecOps* focus will help organizations boost productivity, reduce risk and cultivate a superior **reliability posture** right from the beginning
- ➔ **It is fundamental to pass to evaluate the cost of the entire software lifetime instead of the cost of software production**



Error #1: We Need “Superman” for *DevSecOps*

Not really!

- If you think you need to recruit certain people with all magical coding skills for *DevSecOps*, then you are mistaken
- Unless you cannot train your existing people effectively or your developers are not interested in making the *DevSecOps* shift, you do not have to put on your hiring cap just yet
- *DevSecOps* aims to break down silos. Your development team, which is comprised of people with different skill sets, will receive training on *DevSecOps* processes and methodologies that should hold well throughout your delivery pipeline

It is more convenient bringing together existing teams than hiring a quite new separate team



Error #2: *DevSecOps* can replace agile development

- *DevSecOps* complements agile, but it is not a substitute for it
- They must co-exist in order for organizations to maximize their business benefits
- Agile fosters collaboration and constant feedback, but it does not cover software delivery through testing, QA, and production
- *DevSecOps* completes the picture by providing methodologies and tools to facilitate agile adjustments



Error #3: You can buy *DevSecOps*

Not exactly!

- You can only buy tools to use for the process, such as release management and agile tools, and entire DevSecOps platforms (even for cloud)
- You cannot buy the entire DevSecOps process because it is a daily methodology of working together

What really makes a difference (the disruption of silos, the collaboration between teams, the focus on team responsibility and ownership) are things you cannot go buy outside



Golden rules and best practices

TEAM

- Reduce human error (reduce stress, give pauses/distractions, ...)
- Ensure different teams are communicating and collaborating

KNOWLEDGE AND COMPETENCES

- Train your employees on cybersecurity best practices
- Train your employees on main software vulnerabilities

TOOLS

- Regularly patch hardware and software
- Code scanning, alerts, and notification of security anomalies
- Automation (scanning, discovery, and remediation of security defects)
- Visibility dashboards
- Testing

